

Security Architecture Design & Network Defense Strategy

Robust Defense-in-Depth Architecture for Public Sector E-Governance Platforms

Candidate: Yuva Intern – NSDC | Domain: Zero Trust Architecture & Secure Infrastructure

1. Executive Summary & Design Rationale

Digital public services and e-governance platforms require a highly resilient, scalable, and secure architecture capable of withstanding advanced, persistent cyber threats while ensuring uninterrupted availability for millions of citizens. Traditional perimeter-based network security models are insufficient against modern lateral movement, credential theft, and API-based attacks.

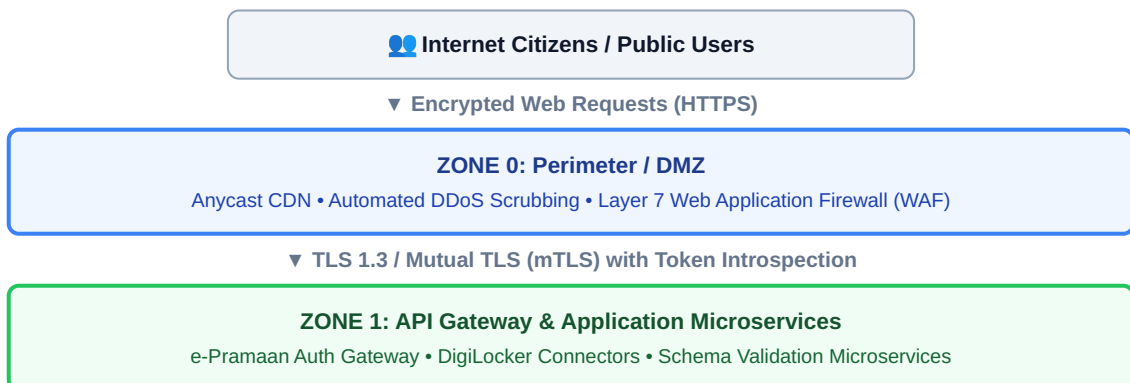
This document outlines a comprehensive Security Architecture Design and Network Defense Strategy based on **NIST SP 800-207 Zero Trust Architecture (ZTA)** principles and a rigorous Defense-in-Depth framework. The architecture ensures strict identity verification, micro-segmentation, continuous behavioral monitoring, and robust cryptographic protection across all layers of the e-governance infrastructure.

2. Network Segmentation & Zoning Architecture

To prevent unauthorized lateral movement and isolate critical municipal and citizen databases from public exposure, the e-governance infrastructure is segregated into isolated security zones protected by Next-Generation Firewalls (NGFW) and internal micro-segmentation gateways.

SECURITY ZONE	NETWORK TIER & COMPONENTS	ACCESS CONTROL & SECURITY CONTROLS
Zone 0: Public DMZ	Anycast CDN, DDoS Scrubbing Centers, Public Load Balancers, WAF appliances.	Strict rate limiting, Layer 7 HTTP/HTTPS inspection, CAPTCHA integration, TLS 1.3 termination.
Zone 1: Application Tier	API Gateways (e-Pramaan, DigiLocker integration), Microservices cluster, Citizen Portal nodes.	Mutual TLS (mTLS), OAuth2 token validation, API schema validation, zero direct DB access.
Zone 2: Secure Database Tier	Citizen Demographic DB, Land Registry, Tax & Treasury DBs (Isolated internal subnet).	Encrypted at rest (AES-256), strict role-based access control (RBAC), database activity monitoring (DAM).
Zone 3: Management & Ops Zone	SIEM collectors, EDR management console, Bastion hosts with Hardware Token MFA.	Jump box isolation, session recording, strict IP whitelisting, multi-person authorization.

2.1 Visual Network Architecture Flow



ZONE 2: Secure Database Tier (Encrypted PII Storage)

AES-256 HSM Encryption • Land Registry • Citizen Master DB • Real-time DAM Telemetry

3. Core Security Controls & Defense Mechanisms

3.1 Perimeter & Web Application Defense

- **Next-Generation Firewalls (NGFW):** Deployed at all zone boundaries with deep packet inspection (DPI) and application-layer awareness.
- **Web Application Firewalls (WAF):** Signature-based and behavioral anomaly-based WAF rules to block SQL injection (SQLi), Cross-Site Scripting (XSS), and Remote Code Execution (RCE).
- **DDoS Mitigation:** Anycast routing combined with automated scrubbing centers to absorb volumetric floods during high-traffic civic deadlines.

3.2 Host & Container Security

- **Endpoint Detection and Response (EDR):** Deployed across all virtual machines and bare-metal servers in the State Data Center for real-time behavioral telemetry.
- **Container Security:** Immutable container images scanned during CI/CD pipelines via Software Bill of Materials (SBOM) generation and runtime vulnerability scanning.

3.3 Cryptographic Standards

- **Data in Transit:** Mandatory enforcement of TLS 1.3 with Perfect Forward Secrecy (PFS) and strong cipher suites across all public and internal service communications.
- **Data at Rest:** Hardware Security Module (HSM) backed AES-256 encryption for all citizen PII, tax records, and sensitive government databases.

4. Secure Configuration & Hardening Standards

All infrastructure components adhere strictly to Center for Internet Security (CIS) Benchmarks and National Institute of Standards and Technology (NIST) hardening guidelines:

- **OS & Server Hardening:** Removal of unnecessary packages, disabling legacy protocols (SMBv1, Telnet, FTP), enforcing strict password complexity, and account lockout policies.
- **Principle of Least Privilege (PoLP):** Administrative access granted strictly on a role-based, time-bounded basis utilizing Privileged Access Management (PAM) solutions with mandatory session recording.
- **API Gateway Hardening:** Mandatory OAuth 2.0 / OpenID Connect token verification, strict request schema validation, and rate-limiting to prevent credential stuffing and brute-force harvesting.

5. Proactive Monitoring, SIEM & Threat Detection

Security visibility is maintained through a centralized Security Information and Event Management (SIEM) platform integrated with User and Entity Behavior Analytics (UEBA):

- **Centralized Log Aggregation:** Real-time ingestion of syslogs, WAF logs, firewall audit trails, authentication events, and database query logs into a tamper-evident SIEM repository.
- **Automated Threat Hunting:** Continuous automated threat hunting playbooks searching for indicators of compromise (IoCs), anomalous API access patterns, and unauthorized privilege escalation.
- **Incident Response Integration:** Automated ticketing and SOAR (Security Orchestration, Automation, and Response) triggers for P1 and P2 security alerts, ensuring triage within 15 minutes.

6. Compliance & Industry Standards Alignment

The proposed security architecture aligns directly with national and international regulatory standards:

- **NIST SP 800-207:** Zero Trust Architecture implementation guidelines.
- **ISO/IEC 27001:2022:** Information security management systems requirements.
- **CERT-In Guidelines:** National cybersecurity directives for mandatory log retention and incident reporting.
- **National Data Protection Legislation:** Compliance frameworks ensuring citizen privacy, consent management, and data sovereignty.